

Manual 30 — Implementación controlada de integración GRC empresarial y crosswalks

****Idioma:**** Español de América Latina (es-419)

****Límite controlado:**** Este manual es una metodología original de integración sobre la serie publicada de manuales GRC. No crea obligaciones legales, no sustituye fuentes autoritativas y no implica equivalencia entre leyes, normas, marcos, contratos o sistemas de control distintos.

Chapter 01 — Propósito, alcance y principio de no equivalencia

Establezca el crosswalk empresarial como una capa gobernada de apoyo a decisiones. Cada mapeo debe conservar diferencias de propósito, alcance, aplicabilidad, terminología, nivel de aseguramiento y efecto jurídico.

Chapter 02 — Registro de fuentes/versiones y control de cambios

Mantenga un registro para cada ley, norma, marco, manual, contrato y guía mapeada. Registre versión, fecha efectiva, estado de la fuente, propietario, fecha de validación y disparador de seguimiento de cambios.

Chapter 03 — Modelo de objeto de obligación empresarial

Represente cada obligación como un registro discreto con fuente, referencia, aplicabilidad, entidad responsable, resultado requerido, plazo, expectativa de evidencia y notas de interpretación. No fusione obligaciones distintas solo por compartir un tema.

Chapter 04 — Modelo canónico de objeto de control

Use un registro canónico con objetivo, propietario, alcance, frecuencia, procedimiento, evidencia, método de prueba, dependencias, excepciones y estado de ciclo de vida. Un control puede apoyar múltiples obligaciones sin borrar su contexto original.

Chapter 05 — Taxonomía y modelo de objeto de riesgo

Normalice riesgos mediante causa, evento, impacto, activos/procesos, riesgo inherente, controles, riesgo residual, propietario, tratamiento y disparador de revisión. Preserve conceptos específicos cuando normalizarlos elimine significado.

Chapter 06 — Jerarquía de políticas y estándares

Mapee políticas y estándares internos a obligaciones y controles con relaciones explícitas. Distinga compromisos de política, estándares internos obligatorios, procedimientos y requisitos externos.

Chapter 07 — Relaciones entre procedimientos y controles operativos

Vincule procedimientos con los controles que operacionalizan e identifique responsable, frecuencia, entradas, salidas, evidencia y ruta de excepción. Un procedimiento documentado no demuestra por sí mismo operación efectiva.

Chapter 08 — Arquitectura de objetos de evidencia

Cree objetos de evidencia con propietario, sistema fuente, periodo, método de recolección, atributos de integridad, retención, restricciones de acceso y controles relacionados. La reutilización debe justificarse por alcance y periodo.

Chapter 09 — Arquitectura de objetos de prueba y aseguramiento

Represente pruebas de forma independiente con población, muestra, procedimiento, criterio, evaluador, resultado, excepciones y nivel de aseguramiento. La reutilización debe conservar objetivo y limitaciones originales.

Chapter 10 — Objetos de excepción y aceptación de riesgo

Registre excepciones con obligación/control afectado, justificación, medidas compensatorias, evaluación de riesgo, autoridad aprobadora, vigencia, monitoreo y disparador de renovación. Ningún crosswalk debe convertir silenciosamente una excepción en cumplimiento.

Chapter 11 — Objetos de hallazgo, asunto y remediación

Normalice hallazgos preservando origen, método de severidad, fuente afectada, evidencia, causa raíz, responsable, fecha objetivo, criterio de validación y evidencia de cierre. Las escalas de severidad se mapean; no se sobrescriben.

Chapter 12 — Propiedad, responsabilidad y relaciones RACI

Asigne responsables para fuentes, mapeos, controles, evidencias, pruebas, riesgos y asuntos. RACI debe distinguir rendición de cuentas, ejecución, revisión, consulta y aprobación.

Chapter 13 — Aplicabilidad por entidad, jurisdicción, producto y servicio

Aplique mapeos solo tras definir entidad jurídica, jurisdicción, unidad, producto, servicio, tipo de cliente, contexto de tratamiento y perímetro regulatorio. Las etiquetas corporativas amplias no anulan condiciones más estrechas.

Chapter 14 — Relaciones con activos, procesos, datos, proveedores y tecnología

Conecte obligaciones y controles con activos, procesos, clases de datos, proveedores, aplicaciones, infraestructura, sistemas de IA y OT cuando corresponda. Estas relaciones deben soportar análisis de impacto ante cambios.

Chapter 15 — Mapeos uno-a-uno, uno-a-muchos y muchos-a-muchos

Soporte cardinalidades explícitas. Un requisito puede requerir varios controles y un control puede apoyar varias obligaciones, pero la cobertura se evalúa individualmente en cada dirección.

Chapter 16 — Direccionalidad y mapeos asimétricos

Registre la dirección fuente-destino. Mapear A hacia B no prueba el mapeo inverso, y un control más amplio puede cubrir solo parcialmente una obligación más específica o viceversa.

Chapter 17 — Confianza, justificación y limitaciones del mapeo

Asigne confianza con criterios documentados y registre justificación, supuestos, revisor y limitaciones. Los mapeos de baja confianza requieren validación antes de reutilizarse en auditoría, regulación o certificación.

Chapter 18 — Cobertura parcial y representación de brechas

Use estados explícitos como completa, sustancial, parcial, de apoyo, no aplicable y sin cobertura. Registre elementos no cubiertos y necesidades de remediación en lugar de forzar un resultado binario.

Chapter 19 — Separación entre obligación legal, guía y estándar voluntario

Clasifique las fuentes para distinguir deberes legales, reglas regulatorias, compromisos contractuales, marcos voluntarios, estándares y guías. La similitud de un crosswalk nunca equivale a la misma autoridad jurídica.

Chapter 20 — Herencia de controles y gobierno de controles compartidos

Documente controles heredados y compartidos con proveedor, consumidor, límite de responsabilidad, evidencia, método de aseguramiento y riesgo de dependencia. La herencia exige validar que el alcance upstream cubra realmente el entorno dependiente.

Chapter 21 — Reutilización de evidencia sin afirmar suficiencia falsa

Permita reutilización solo cuando objetivo, alcance, sistema, periodo, población y necesidad de aseguramiento estén alineados. La aceptación de un artefacto por otro marco no demuestra suficiencia universal.

Chapter 22 — Reutilización de pruebas y límites de aseguramiento

Reutilice pruebas solo cuando procedimiento, población, momento, criterio y objetivo sean compatibles. Registre pruebas suplementarias necesarias para cubrir diferencias entre regímenes.

Chapter 23 — Normalización de asuntos entre marcos

Use un registro común de asuntos, conservando requisito afectado y contexto de severidad de cada fuente. Una remediación consolidada solo cierra múltiples asuntos cuando se cumplen criterios específicos de cada fuente.

Chapter 24 — Análisis de impacto por cambio regulatorio

Cuando cambie una fuente, identifique obligaciones, mapeos, controles, políticas, evidencias, pruebas, sistemas, proveedores, métricas y asuntos afectados. El cambio debe activar revalidación dirigida.

Chapter 25 — Gestión de migración de marcos/versiones

Trate la migración como cambio controlado. Mantenga referencias anterior-nueva, adiciones, eliminaciones, cambio de intención, confianza del mapeo, brechas, fechas de transición y evidencia de aprobación.

Chapter 26 — Métricas, agregación y semántica de reportes

Defina fórmula, unidad, población, periodo, umbral, propietario y fuente de datos. Los porcentajes agregados de cumplimiento o cobertura deben revelar exclusiones, supuestos y ponderaciones.

Chapter 27 — Reportes ejecutivos/directorio y apoyo a decisiones

Convierta resultados en temas de decisión: obligaciones materiales, concentración de controles, brechas, aceptación de riesgo, exposición de remediación, cambio regulatorio y estado de aseguramiento. No use conteos de mapeos como prueba de cumplimiento.

Chapter 28 — Paquetes de evidencia para auditor, regulador o cliente

Genere paquetes que preserven requisito fuente, controles mapeados, procedimientos, evidencia, pruebas, excepciones, hallazgos y procedencia. Adapte cada paquete al objetivo de aseguramiento o autoridad solicitante.

Chapter 29 — Controles de calidad de datos y conciliación

Valide integridad referencial, duplicados, mapeos huérfanos, versiones obsoletas, propietarios faltantes, confianza sin soporte, excepciones vencidas y estados inconsistentes. Corrija defectos antes de reportar.

Chapter 30 — Gobierno de aprobaciones y cambios de crosswalk

Defina autores, revisores independientes, criterios de aprobación, historial de cambios, resolución de conflictos, segregación de funciones y disparadores de reaprobación. Los cambios materiales deben ser auditables y reversibles.

Chapter 31 — Localización, accesibilidad, procedencia y pista de auditoría

Mantenga paridad estructural EN/es-419/pt-BR y conserve identificadores de fuente cuando sea necesario. Los artefactos publicados deben retener accesibilidad, procedencia de compilación, hashes, evidencia de revisión e historial del repositorio.

Chapter 32 — Hoja de ruta y mantenimiento de toda la serie

Opere Manual 30 como capa viva sobre la serie publicada. Nuevos manuales, revisiones de fuentes, cambios jurisdiccionales y cambios del modelo de control deben ingresar mediante verificación, impacto, revisión de mapeo, QA, procedencia y gobierno secuencial.

Registro mínimo de crosswalk

Cada mapeo aprobado debe registrar fuente y versión, objeto fuente, destino y versión, objeto destino, dirección, justificación, confianza, cobertura, brechas, nota de no equivalencia, propietario, método de revisión/prueba, dependencias de evidencia y disparador de revalidación.